

A privacy policy is a statement or legal document (in privacy law) that discloses some or all of the ways a party gathers, uses, discloses, and manages a customer or client's data, while a privacy notice tells clients or data subjects what data is held by an organisation and how that data will be handled.

Personal information can be anything that can be used to identify an individual, not limited to the person's name, address, date of birth, marital status, contact information, ID issue, and expiry date, financial records, credit information, medical history, where one travels, and intentions to acquire goods and services. In the case of a business, it is often a statement that declares a party's policy on how it collects, stores, and releases personal information it collects. It informs the client what specific information is collected, and whether it is kept confidential, shared with partners, or sold to other firms or enterprises. Privacy policies typically represent a broader, more generalized treatment, as opposed to data use statements, which tend to be more detailed and specific.

The exact contents of a privacy policy will depend upon the applicable law and may need to address requirements across geographical boundaries and legal jurisdictions. Most countries have their own legislation and guidelines of who is covered, what information can be collected, and what it can be used for. In general, data protection laws in Europe cover the private sector as well as the public sector. Their privacy laws apply not only to government operations but also to private enterprises and commercial transactions.

History

In 1968, the Council of Europe began to study the effects of technology on human rights, recognizing the new threats posed by computer technology that could link and transmit in ways not widely available before. In 1969 the Organisation for Economic Co-operation and Development (OECD) began to examine the implications of personal information leaving the country. All this led the council to recommend that policy be developed to protect personal

data held by both the private and public sectors, leading to Convention 108. In 1981, Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data (Convention 108) was introduced. One of the first privacy laws ever enacted was the Swedish Data Act in 1973, followed by the West German Data Protection Act in 1977 and the French Law on Informatics, Data Banks and Freedoms in 1978.

In the United States, concern over privacy policy starting around the late 1960s and 1970s led to the passage of the Fair Credit Reporting Act. Although this act was not designed to be a privacy law, the act gave consumers the opportunity to examine their credit files and correct errors. It also placed restrictions on the use of information in credit records. Several congressional study groups in the late 1960s examined the growing ease with which automated personal information could be gathered and matched with other information. One such group was an advisory committee of the United States Department of Health and Human Services, which in 1973 drafted a code of principles called the Fair Information Practices. The work of the advisory committee led to the Privacy Act in 1974. The United States signed the Organisation for Economic Co-operation and Development guidelines in 1980.

In Canada, a Privacy Commissioner of Canada was established under the Canadian Human Rights Act in 1977. In 1982, the appointment of a Privacy Commissioner was part of the new Privacy Act. Canada signed the OECD guidelines in 1984.

Fair information practice

There are significant differences between the EU data protection and US data privacy laws. These standards must be met not only by businesses operating in the EU but also by any organization that transfers personal information collected concerning citizens of the EU. In 2001 the United States Department of Commerce worked to ensure legal compliance for US organizations under an opt-in Safe Harbor Program. The FTC has approved eTRUST to certify streamlined compliance with the US-EU Safe Harbor.

Current enforcement

In 1995 the European Union (EU) introduced the Data Protection Directive for its member states. As a result, many organizations doing business within the EU began to draft policies to comply with this Directive. In the same year, the U.S. Federal Trade Commission (FTC) published the Fair Information Principles which provided a set of non-binding governing principles for the commercial use of personal information. While not mandating policy, these principles provided guidance of the developing concerns of how to draft privacy policies.

The United States does not have a specific federal regulation establishing universal implementation of privacy policies. Congress has, at times, considered comprehensive laws regulating the collection of information online, such as the Consumer Internet Privacy Enhancement Act and the Online Privacy Protection Act of 2001, but none have been enacted. In 2001, the FTC stated an express preference for "more law enforcement, not more laws" and promoted continued focus on industry self-regulation.

In many cases, the FTC enforces the terms of privacy policies as promises made to consumers using the authority granted by Section 5 of the FTC Act which prohibits unfair or deceptive marketing practices. The FTC's powers are statutorily restricted in some cases; for example, airlines are subject to the authority of the Federal Aviation Administration (FAA), and cell phone carriers are subject to the authority of the Federal Communications Commission (FCC).

In some cases, private parties enforce the terms of privacy policies by filing class action lawsuits, which may result in settlements or judgments. However, such lawsuits are often not an option, due to arbitration clauses in the privacy policies or other terms of service agreements.

Applicable law

United States

While no generally applicable law exists, some federal laws govern privacy policies in specific circumstances, such as:

The Children's Online Privacy Protection Act (COPPA) affects websites that knowingly collect information about or targeted at children under the age of 13. Any such websites must post a privacy policy and adhere to enumerated information-sharing restrictions. COPPA includes a "safe harbor" provision to promote Industry self-regulation.

The Gramm-Leach-Bliley Act requires institutions "significantly engaged" in financial activities give "clear, conspicuous, and accurate statements" of their information-sharing practices. The Act also restricts use and sharing of financial information.

The Health Insurance Portability and Accountability Act (HIPAA) privacy rules requires notice in writing of the privacy practices of health care services, and this requirement also applies if the health service is electronic.

The California Consumer Privacy Act (CCPA) gives consumers more control over the personal information that businesses collect about them and the CCPA regulations provide guidance on how to implement the law.

The California Privacy Rights Act of 2020 (CPRA) expands the privacy and information security obligations of most employers doing business in California.

Some states have implemented more stringent regulations for privacy policies. The California Online Privacy Protection Act of 2003 – Business and Professions Code sections 22575-22579 requires "any commercial websites or online services that collect personal information on California residents through a web site to conspicuously post a privacy policy on the site". Both Nebraska and Pennsylvania have laws treating misleading statements in privacy policies published on websites as deceptive or fraudulent business practices.

Canada

Canada's federal Privacy Law applicable to the private sector is formally referred to as Personal Information Protection and Electronic Documents Act (PIPEDA). The purpose of the act is to establish rules to govern the collection, use, and disclosure of personal information by commercial organizations. The organization is allowed to collect, disclose and use the amount of information for the purposes that a reasonable person would consider appropriate in the circumstance.

The Act establishes the Privacy Commissioner of Canada as the Ombudsman for addressing any complaints that are filed against organizations. The Commissioner works to resolve problems through voluntary compliance, rather than heavy-handed enforcement. The Commissioner investigates complaints, conducts audits, promotes awareness of and undertakes research about privacy matters.

European Union

The right to privacy is a highly developed area of law in Europe. All the member states of the European Union (EU) are also signatories of the European Convention on Human Rights (ECHR). Article 8 of the ECHR provides a right to respect for one's "private and family life, his home and his correspondence", subject to certain restrictions. The European Court of Human Rights has given this article a very broad interpretation in its jurisprudence.

In 1980, in an effort to create a comprehensive data protection system throughout Europe, the Organization for Economic Co-operation and Development (OECD) issued its "Recommendations of the Council Concerning Guidelines Governing the Protection of Privacy and Trans-Border Flows of Personal Data". The seven principles governing the OECD's recommendations for protection of personal data were:

Notice—data subjects should be given notice when their data is being collected;

Purpose—data should only be used for the purpose stated and not for any other purposes;

Consent—data should not be disclosed without the data subject's consent;

Security—collected data should be kept secure from any potential abuses;

Disclosure—data subjects should be informed as to who is collecting their data;

Access—data subjects should be allowed to access their data and make corrections to any inaccurate data; and

Accountability—data subjects should have a method available to them to hold data collectors accountable for not following the above principles.

The OECD guidelines, however, were nonbinding, and data privacy laws still varied widely across Europe. The US, while endorsing the OECD's recommendations, did nothing to implement them within the United States. However, all seven principles were incorporated into the EU Directive.

In 1995, the EU adopted the Data Protection Directive, which regulates the processing of personal data within the EU. There were significant differences between the EU data protection and equivalent U.S. data privacy laws. These standards must be met not only by businesses operating in the EU but also by any organization that transfers personal information collected concerning a citizen of the EU. In 2001 the United States Department of Commerce worked to ensure legal compliance for US organizations under an opt-in Safe Harbor Program. The FTC has approved a number of US providers to certify compliance with the US-EU Safe Harbor. Since 2010 Safe Harbor is criticised, especially by German publicly appointed privacy protectors, because the FTC's will to assert the defined rules had not been implemented in a proper manner even after revealing disharmonies.

From 25 May 2018, the Data Protection Directive was superseded by the General Data Protection Regulation (GDPR), which harmonizes privacy rules across all EU member states. GDPR imposes more stringent rules on the collection of personal information belonging to EU data subjects, including a requirement for privacy policies to be more concise, clearly-worded, and transparent in their disclosure of any collection, processing, storage, or transfer of

personally identifiable information. Data controllers must also provide the opportunity for their data to be made portable in a common format, and for it to be erased under certain circumstances.

Australia

The Privacy Act 1988 provides the legal framework for privacy in Australia. It includes a number of national privacy principles. There are thirteen privacy principles under the Privacy Act. It oversees and regulates the collection, use and disclosure of people's private information, makes sure who is responsible if there is a violation, and the rights of individuals to access their information.

India

The Information Technology (Amendment) Act, 2008 made significant changes to the Information Technology Act, 2000, introducing Section 43A. This section provides compensation in the case where a corporate body is negligent in implementing and maintaining reasonable security practices and procedures and thereby causes wrongful loss or wrongful gain to any person. This applies when a corporate body possesses, deals or handles any sensitive personal data or information in a computer resource that it owns, controls or operates.

In 2011, the Government of India prescribed the Information Technology (Reasonable security practices and procedures and sensitive personal data or information) Rules, 2011 by publishing it in the Official Gazette. These rules require a body corporate to provide a privacy policy for handling of or dealing in personal information including sensitive personal data or information. Such a privacy policy should consist of the following information in accordance with the rules:

Clear and easily accessible statements of its practices and policies;

Type of personal or sensitive personal data or information collected;

Purpose of collection and usage of such information;

Disclosure of information including sensitive personal data or information;

Reasonable security practices and procedures.

The privacy policy should be published on the website of the body corporate, and be made available for view by providers of information who have provided personal information under lawful contract.

Online privacy certification programs

Online certification or "seal" programs are an example of industry self-regulation of privacy policies. Seal programs usually require implementation of fair information practices as determined by the certification program and may require continued compliance monitoring. TRUSTArc (formerly TRUSTe), the first online privacy seal program, included more than 1,800 members by 2007. Other online seal programs include the Trust Guard Privacy Verified program, eTrust, and Webtrust.

Technical implementation

Some websites also define their privacy policies using P3P or Internet Content Rating Association (ICRA), allowing browsers to automatically assess the level of privacy offered by the site, and allowing access only when the site's privacy practices are in line with the user's privacy settings. However, these technical solutions do not guarantee websites actually follows the claimed privacy policies. These implementations also require users to configure their own browser privacy settings or accept a recommended set of settings. These automated privacy policies have not been popular either with websites or their users. To reduce the burden of interpreting individual privacy policies, re-usable, certified policies

available from a policy server have been proposed by Jøsang, Fritsch and Mahler.

Other efforts at technical approaches have included XACML (Extensible Access Control Markup Language) and Enterprise Privacy Authorization Language, which are frameworks for expressing privacy policies in machine-readable language that a software system can use to enforce policies in enterprise IT systems.

Criticism

Many critics have attacked the efficacy and legitimacy of privacy policies found on the Internet.

Concerns exist about the effectiveness of industry-regulated privacy policies. For example, a 2000 FTC report *Privacy Online: Fair Information Practices in the Electronic Marketplace* found that while the vast majority of websites surveyed had some manner of privacy disclosure, most did not meet the standard set in the FTC Principles. In addition, many organizations reserve the express right to unilaterally change the terms of their policies. In June 2009 the EFF website TOSback began tracking such changes on 56 popular internet services, including monitoring the privacy policies of Amazon, Google and Facebook.

There are also questions about whether consumers understand privacy policies and whether they help consumers make more informed decisions. A 2002 report from the Stanford Persuasive Technology Lab contended that a website's visual designs had more influence than the website's privacy policy when consumers assessed the website's credibility. A 2007 study by Carnegie Mellon University claimed "when not presented with prominent privacy information..." consumers were "...likely to make purchases from the vendor with the lowest price, regardless of that site's privacy policies". However, the same study also showed that when information about privacy practices is clearly presented, consumers prefer retailers who better protect their privacy and some are willing to "pay a premium to purchase from more privacy protective websites". Furthermore, a 2007 study at the University of California,

Berkeley found that "75% of consumers think as long as a site has a privacy policy it means it won't share data with third parties," confusing the existence of a privacy policy with extensive privacy protection. Based on the common nature of this misunderstanding, researcher Joseph Turow argued to the U.S. Federal Trade Commission that the term "privacy policy" thus constitutes a deceptive trade practice and that alternative phrasing like "how we use your information" should be used instead.

Privacy policies suffer generally from a lack of precision, especially when compared with the emerging form of the Data Use Statement. Where privacy statements provide a more general overview of data collection and use, data use statements represent a much more specific treatment. As a result, privacy policies may not meet the increased demand for transparency that data use statements provide.

Critics also question if consumers even read privacy policies or can understand what they read. A 2001 study by the Privacy Leadership Initiative claimed only 3% of consumers read privacy policies carefully, and 64% briefly glanced at, or never read privacy policies. The average website user once having read a privacy statement may have more uncertainty about the trustworthiness of the website than before. One possible issue is length and complexity of policies. According to a 2008 Carnegie Mellon study, the average length of a privacy policy is 2,500 words and requires an average of 10 minutes to read. The study cited that "Privacy policies are hard to read" and, as a result, "read infrequently". However, any efforts to make the information more presentable simplify the information to the point that it does not convey the extent to which users' data is being shared and sold. This is known as the "transparency paradox".

There have been many studies carried out by researchers to evaluate the privacy policies of the websites of companies. One study uses natural language processing and deep learning as a proposed solution to automatically assess the efficiency of companies' privacy policies, in order to help the users become more aware.

References

Further reading

Gazaleh, Mark (2008), Online trust and perceived utility for consumers of web privacy statements, WBS London, 35pp.

Cavoukian, Ann (1995). Who Knows: Safeguarding Your Privacy in A Networked Worldwide (paperback). Random House of Canada: Random House. ISBN 0-394-22472-8.